Nhill 2.1 — Sécurité

English: ../en/security.md

Ce document résume le modèle de sécurité de Nhill 2.1, ce qui a changé depuis la 0.1.0 et ce que l'exploitant doit faire. L'analyse détaillée, avec preuves et sources, est dans l'audit de sécurité ; l'audit interne 0.1.0 (preuves par tests) est conservé dans `docs/securite.md`.

> Nhill n'a fait l'objet **d'aucun audit externe ni test d'intrusion**. Les mesures décrites réduisent les risques ; elles ne garantissent pas l'absence de vulnérabilité.

1. Principes

- **Le serveur décide** : rôles, permissions, abonnement, plafonds, autorisations de superviseur sont vérifiés côté serveur sur chaque route. Masquer un bouton n'est jamais une mesure de sécurité.
- **Isolation par la base** : RLS forcée sur les 30 tables métier ; le rôle applicatif ne possède aucun objet et ne contourne pas la RLS ; une violation renvoie 404.
- **Aucun secret dans les applications ni dans le dépôt** : pas d'identifiant de base, pas de clé Supabase (`service_role` jamais utilisée), pas de secret de prestataire.
- **Un identifiant n'est pas une autorisation** : ni l'identifiant d'un établissement, ni son code renouvelable, ni l'identifiant d'un ticket ne donne accès à quoi que ce soit.
- **Traçabilité** : journal d'audit en ajout seul, consultable par l'établissement.

2. Mots de passe et authentification (2.0, complétés en 2.1)

Élément	Règle	Justification
Longueur minimale	**8 caractères** pour tous les comptes (création, invitation, changement, console, réinitialisation, remplacement d'un mot de passe temporaire)	exigence du projet ; NIST SP 800-63B-4 fixe 8 avec authentification multifacteur et recommande 15 pour un mot de passe seul (§ 3)
Validation	même fonction C++ dans les applications (avant l'envoi) et dans le serveur (décision)	une seule règle, impossible à contourner par un client modifié
Mots de passe refusés	liste de mots de passe courants (40 entrées : « 12345678 », « password », « azerty123 », « kinshasa »…), identique à l'e-mail, répétitif	NIST : refuser les mots de passe connus compromis ou attendus
Composition imposée	**aucune** (pas d'obligation de chiffres ou de symboles)	NIST : les règles de composition n'améliorent pas la sécurité réelle
Changement périodique	**aucun** ; changement exigé seulement en cas de compromission	NIST : l'expiration périodique pousse à des mots de passe faibles
Stockage	Argon2id (libsodium, 3 passes, 64 Mio), jamais en clair, jamais dans les journaux	—
Affichage	bouton afficher/masquer dans chaque champ	réduit les erreurs de saisie, permet des phrases de passe

Élément	Règle	Justification
Tentatives	limitées en base (connexion : 8 par 15 min et par e-mail, 40 par adresse IP ; console : 5 par compte, 20 par IP ; mot de passe oublié : 3 demandes de code par heure et par adresse, 10 par IP ; 10 vérifications de code par 15 min et par adresse, 20 par IP ; 5 codes erronés annulent le code)	ralentit les attaques par essais
Sessions	jetons opaques, accès 15 min, renouvellement 30 jours avec rotation et détection de réutilisation ; changement de mot de passe = fermeture des autres sessions ; réinitialisation (code ou administrateur) = fermeture de toutes les sessions	—
Double authentification	**obligatoire pour Nhill Console** (TOTP) ; **non imposée** aux établissements	la console donne accès à toute la plateforme : protection indispensable conservée

3. Risque accepté : 8 caractères

La longueur minimale de 8 caractères est une exigence du projet. Pour un mot de passe utilisé **sans** second facteur, NIST SP 800-63B-4 (§ 3.1.1.2) recommande au moins 15 caractères. Les comptes des établissements n'ayant pas de second facteur, le risque de devinette en ligne est compensé par la limitation des tentatives et la liste de refus, et celui de cassage hors ligne (après une fuite de la base) par Argon2id. **Le propriétaire du produit doit consigner cette décision** (registre des décisions) et la réexaminer quand la double authentification optionnelle sera disponible pour les propriétaires.

Conseils donnés aux utilisateurs (application, site, FAQ) : une courte phrase plutôt qu'un mot, un mot de passe propre à Nhill, un gestionnaire de mots de passe.

4. Changements de sécurité en 2.0

Changement	Effet
Règle de 8 caractères unifiée (suppression de la règle de 14 caractères de la console)	cohérence ; TOTP de la console conservé
Liste des mots de passe refusés élargie (8 caractères courants)	compense l'abaissement de 10 à 8
`X-Forwarded-For` : entrée la plus à droite	un client ne peut plus choisir l'adresse vue par les limites de débit derrière un proxy qui ajoute l'en-tête
Paquets Debian 13 construits contre le Qt de Debian	les correctifs de sécurité Qt de Debian s'appliquent (la 0.1.0 embarquait Qt 6.4.2)
Journal d'activité : champs techniques masqués	moins d'identifiants internes affichés
Site vitrine : base et rôles distincts, rôle web en insertion seule	une compromission du site n'expose ni l'application ni les demandes déjà reçues

4 bis. Changements de sécurité en 2.1

Changement	Effet
« Se souvenir de moi » : le jeton de renouvellement (jamais le mot de passe) est gardé par QtKeychain — Gestionnaire d'identification Windows (DPAPI, utilisateur courant), Keystore Android (clé RSA-2048 non exportable, données chiffrées en AES-GCM), Secret Service ou KWallet sous Linux	sans stockage sécurisé disponible, la session n'est **pas** mémorisée : aucun repli en clair. La case est décochée par défaut ; « Se déconnecter » efface l'entrée
QtKeychain 0.17.0 compilé depuis sa source officielle, commit vérifié (875f77d9…) ; lié statiquement sous Windows et Android	aucune DLL tierce à côté de l'application (pas de substitution de DLL) ; chaque exécutable Windows est contrôlé (imports CredReadW/CredWriteW/CredDeleteW)
Mot de passe temporaire donné par l'administrateur d'un établissement	réservé aux membres de **son** établissement (`users.manage`), pas au propriétaire, pas à soi-même, pas à un compte partagé avec un autre établissement ; 12 caractères aléatoires, Argon2id, affichés une seule fois ; valable 72 h ; seule une connexion vers le changement obligatoire est possible ; sessions du membre fermées ; action journalisée sans le mot de passe
Changement obligatoire	la connexion avec un mot de passe temporaire ne donne qu'un ticket à usage unique (15 min, haché en SHA-256) ; le nouveau mot de passe doit respecter la règle et différer du temporaire
Mot de passe oublié par e-mail (propriétaire, administrateur, compte de plusieurs établissements)	code à 8 chiffres, haché par HMAC-SHA-256 avec une clé du serveur dérivée de `NH_SECRET_KEY`, valable 20 min, 5 essais ; une nouvelle demande annule la précédente ; réponse 202 identique que l'adresse existe ou non ; le code n'est chiffré dans la file d'envoi que le temps de l'envoi, puis effacé
Envoi SMTP (libcurl)	TLS obligatoire (smtps ou STARTTLS) avec vérification du certificat et du nom ; `NH_SMTP_TLS=off` refusé hors relais local ; mot de passe du relais lu dans un fichier en mode 600, jamais journalisé ; en-têtes protégés contre l'injection

Limites connues : le Gestionnaire d'identification Windows conserve l'entrée après une désinstallation tant que l'utilisateur ne s'est pas déconnecté ; un appareil Android sans verrouillage d'écran protège moins le Keystore ; les applications 2.0 ne gèrent pas le changement obligatoire (mettre à jour les postes avant d'utiliser la réinitialisation par l'administrateur).

5. Vulnérabilités connues des dépendances

Dépendance	Avis	Situation	Action
cpp-httplib 0.14 (paquet Ubuntu 24.04 / Debian)	CVE-2025-46728, CVE-2025-53629 (épuisement mémoire, CVSS 7,5)	atténué par Caddy (`request_body max_size`)	**priorité 1** : passer à cpp-httplib ≥ 0.23.0, relancer les tests serveur
Qt 6.4.2 embarqué (variante « debian-13-embedded »)	CVE-2024-39936 et avis postérieurs	variante déconseillée, non livrée par défaut	utiliser les paquets natifs

6. Ce que l'exploitant doit faire

Avant l'ouverture commerciale :

- ☐ Sauvegarder `NH_SECRET_KEY` dans un coffre, séparément des sauvegardes de la base.
- ☐ Caddy devant le serveur (TLS, HSTS), serveur à l'écoute sur `127.0.0.1` uniquement, pare-feu limité à 80/443 et à l'administration.
- ☐ Sauvegardes chiffrées quotidiennes et **test de restauration** ; envisager l'archivage continu des WAL (perte possible jusqu'à 24 h sinon).
- ☐ Supervision : `/health`, échecs de sauvegarde, expiration du certificat, disque, erreurs 5xx.
- ☐ Comptes de la console : rôle minimal, TOTP sur un appareil personnel, phrase de passe longue.
- ☐ Prestataires de paiement en mode test jusqu'à un paiement réel de contrôle.
- ☐ Relais SMTP configuré (`NH_EMAIL_TRANSPORT=smtp`, TLS, SPF/DKIM du domaine expéditeur) et testé : sans lui, propriétaires et administrateurs ne peuvent pas récupérer un mot de passe oublié.
- ☐ Formalités « données personnelles » en RDC (voir parametres-legaux.md).
- ☐ Test d'intrusion externe avant un déploiement large.
- ☐ Signer les installateurs Windows et l'APK avec les certificats de l'éditeur.

En exploitation : mettre à jour le système et les paquets Nhill ; surveiller les avis de sécurité de cpp-httplib, Qt, libsodium, libpqxx, PostgreSQL ; faire tourner les identifiants après tout départ d'un administrateur.

7. Signaler une vulnérabilité

Adresse de signalement : **à définir par les créateurs** (par exemple `security@<domaine>`, publiée sur le site et dans un fichier `security.txt`). Engagements à fixer : accusé de réception, délai de correction, mention des découvreurs. Ne publiez pas de détail exploitable avant la correction.